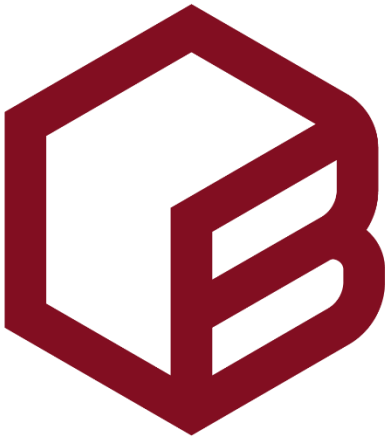
# Key Logger Attack

*Metody ochrony cyberprzestrzeni - projekt*



**POLITECHNIKA BYDGOSKA**

im. Jana i Jędrzeja Śniadeckich

Autor projektu:
Robert Łęgowski (109638)

# *Czym jest Key Logger?*

Keylogger jest programem lub urządzeniem, którego zadaniem jest rejestrowanie działania klawiatury użytkownika, w tym przede wszystkim każdego naciśnięcia klawisza. W ten sposób haker może łatwo zebrać wszystkie potrzebne mu informacje – dane dostępowe do portali, wrażliwe dane osobowe czy szczegóły dotyczące prywatnego życia, które następnie mogą być wykorzystane przy próbach szantażu.

W wielu przypadkach użytkownik przez długi czas pozostaje nieświadomy obecności keyloggera na swoim urządzeniu. Stosowny program trafia do systemu ofiary jak większość złośliwego oprogramowania – w wyniku skutecznej akcji phishingowej, która skłoniła odbiorcę do kliknięcia w link z keyloggerem lub pobrała i otworzyła zainfekowany plik. Często stanowi on element składowy wirusa, instalowany na przykład wraz z ransomware.

Nie każdy keylogger jest jednak złośliwym oprogramowaniem. Może nim być np. aplikacja sieciowa sprawdzająca poprawność wpisywanych treści językowych, która wykorzystuje monitoring zapisywanych znaków i słów, by realizować swoje zadania i wskazywać błędy. Na tej zasadzie operują także autouzupełniania w smartfonach czy popularne narzędzia kontroli rodzicielskiej, które opiekunowie umieszczają na urządzeniach dzieci.

Niektórzy hakerzy wykorzystują monitoring wideo, aby zobaczyć połączenie między naciskanymi klawiszami a tym, co pojawia się na monitorze. Można skonfigurować kamerę wideo z widokiem na klawiaturę i ekran. Po nagraniu wideo z naciśnięć klawiszy i ekranów logowania lub uwierzytelniania, przez które trzeba przejść, haker może odtworzyć wideo, spowolnić je i zobaczyć, które klawisze zostały naciśnięte.

## *Plan projektu*

1. Utworzenie prostej aplikacji umożliwiającej logowanie się użytkowników.
2. Zaprojektowanie i implementacja key logger'a.
3. Opracowanie metod zabezpieczających przed atakami przy pomocy key logger'a.
4. Przeprowadzenie ataku w warunkach bez zabezpieczeń oraz z opracowanymi zabezpieczeniami.
5. Wnioski i podsumowanie projektu.

## *Potencjalny plan ataku*

1. Wysłanie wiadomości email z prośbą o zalogowanie się do swojego konta np. bankowego. W wiadomości email będzie znajdował się link, który pobierze w tle odpowiedniego wirusa i zainstaluje go w systemie oraz przeniesie użytkownika na odpowiednią stronę.
2. Instalacja i uruchomienie keylogger'a w tle, tak aby użytkownik nie był świadomy, że jest atakowany.
3. Przechwycenie przez keylogger'a danych wpisanych przez użytkownika i wysłanie ich na adres atakującego.
4. Zalogowanie się atakującego na konto ofiary.
5. Powtórzenie ataku z włączonymi zabezpieczeniami.

# *User stories*

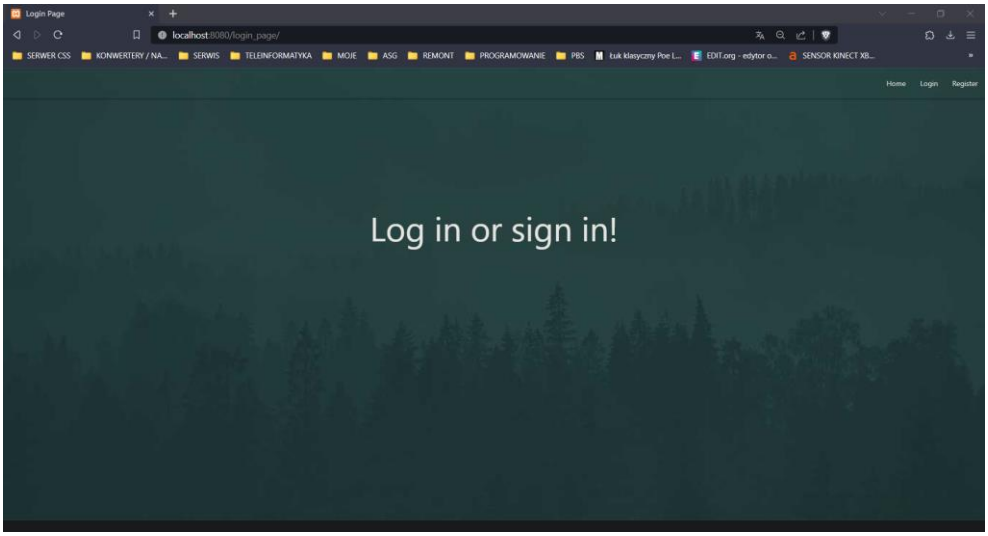
| ***Rola użytkownika*** | ***Cel*** | ***Korzyść*** |
|---|---|---|
| Użytkownik aplikacji | Możliwość wprowadzenia nazwy użytkownika / loginu | Możliwość zalogowania się do swojego konta aby zrealizować jakieś operacje bądź zadania |
| Użytkownik aplikacji | Możliwość wprowadzenia hasła | Możliwość zalogowania się do swojego konta aby zrealizować jakieś operacje bądź zadania |
| Użytkownik aplikacji | Możliwość utworzenia konta w serwisie | Uzyskanie dostępu do poszczególnych funkcjonalności jakie oferuje portal internetowy |
| Użytkownik aplikacji | Otrzymanie maila potwierdzającego założenie konta z linkiem aktywacyjnym | Pewność, że nikt nie wykorzysta naszych danych do założenia konta na portalach internetowych |
| Użytkownik aplikacji | Weryfikacja loginu oraz hasła oraz informacja na temat prawidłowości wpisanych danych | Świadomość błędnego lub poprawnego wpisania danych autoryzujących |
| Użytkownik aplikacji | Przycisk umożliwiający zmianę hasła znajdujący się na stronie logowania | Możliwość zmiany hasła w przypadku jego utraty |
| Użytkownik aplikacji | Możliwość zmiany hasła w przypadku jego zapomnienia | W przypadku utraty danych logowania użytkownik ma możliwość |

| | | |
|---|---|---|
| | | przywrócenia dostępu do swojego konta |
| Użytkownik aplikacji | Jako użytkownik chcę otrzymać wiadomość email z linkiem do zmiany hasła, jeżeli rozpocząłem taką procedurę | Odzyskanie dostępu do swojego konta, w przypadku utraty hasła |
| Użytkownik aplikacji | Informacja o dacie i czasie ostatniego logowania przez użytkownika | Informacja ta może pomóc nam w odkryciu, iż ktoś posiada dane do naszego konta i logował się do niego bez naszej wiedzy |
| Użytkownik aplikacji | Jako użytkownik chcę, aby nieudane próby logowania blokowały dostęp do mojego konta oraz abym otrzymał informację na email o takim zdarzeniu | Zwiększenie bezpieczeństwa konta w przypadku różnego rodzaju ataków |
| Użytkownik aplikacji | Jako użytkownik chcę mieć możliwość odzyskania dostępu do swojego konta w przypadku jego zablokowania po 3 nieudanych próbach logowania. Dostęp ten powinien być odblokowany w formie wiadomości email z linkiem przywracającym dostęp do konta | Odzyskanie dostępu do swojego konta w przypadku zablokowania do niego dostępu. |
| Użytkownik aplikacji | Zmiana danych swojego konta takich jak login, email i hasło | W przypadku podejrzenia pozyskania przez |

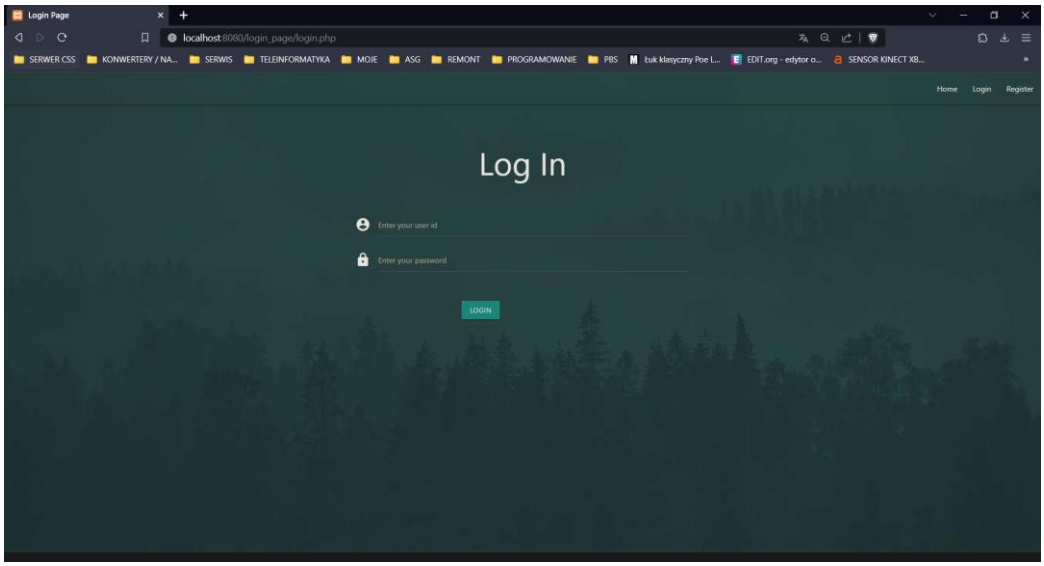
| | | |
|---|---|---|
| | | kogoś dostępu do naszego konta jest to opcja umożliwiająca zabezpieczenie naszego konta |
| Użytkownik aplikacji | Jako użytkownik chcę otrzymać wiadomość email po zmianie danych swojego konta z wyszczególnieniem co zostało zmienione oraz kiedy ta procedura została przeprowadzona | Informacja o zmianie danych do konta zwiększa bezpieczeństwo konta oraz informuje nas przed nieautoryzowanym dostępem do naszych danych |

# *Tworzenie komponentów do przeprowadzenia symulacji ataku*

Aby przeprowadzić symulację ataku niezbędne jest utworzenie prostej aplikacji internetowej obsługującej logowanie – zostanie ona utworzona w języku PHP w połączeniu z bazą danych MySQL. Następnie przy pomocy języka Python zostanie utworzony skrypt – program do przechwytywania liter wpisywanych przez potencjalną ofiarę.

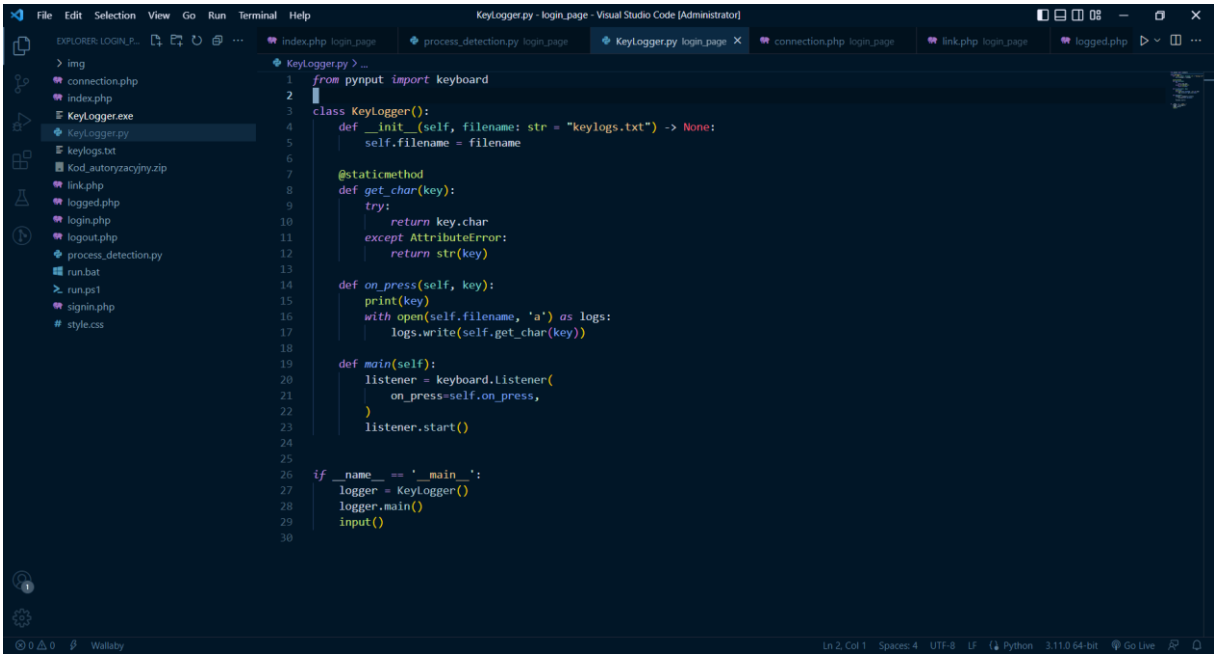



*Rys 1. Prosta aplikacja obsługująca rejestrację i logowanie użytkowników.*



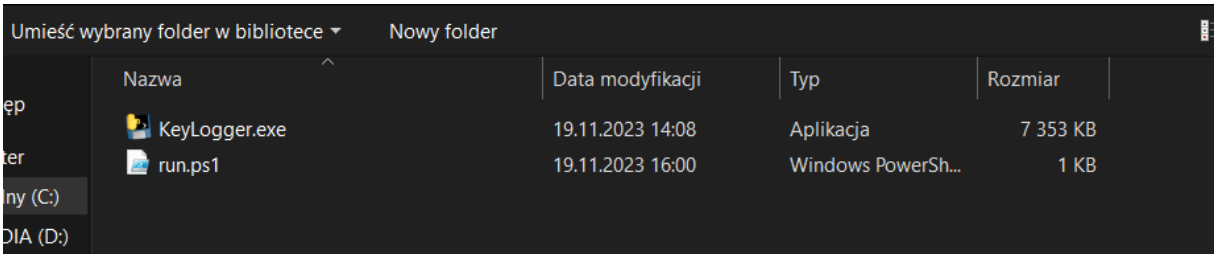

*Rys 2. Strona logowania do aplikacji.*

Samo założenie ataku jest takie, że osoba atakująca wysyła wiadomość email do ofiary z prośbą o zalogowanie się na swoje konto pod pretekstem utraty do niego dostępu. Link do serwisu takiego jak np. mBANK zostanie skonstruowany w ten sposób, że osoba która go otworzy zostanie przekierowana na prawdziwą stronę dopiero wtedy, gdy pobierze skrypt na swój komputer. W momencie pobrania skryptu jest on automatycznie wypakowywany oraz uruchamiany w tle, a użytkownik nie świadomy tych rzeczy jest przekierowywany na prawdziwą stronę np. banku. Następuje logowanie i keylogger działający w tle przechwytuje wszystkie znaki, które są wpisywane przez użytkownika do pliku log. Plik ten po zakończonym ataku zostanie przesłany na email atakującego.



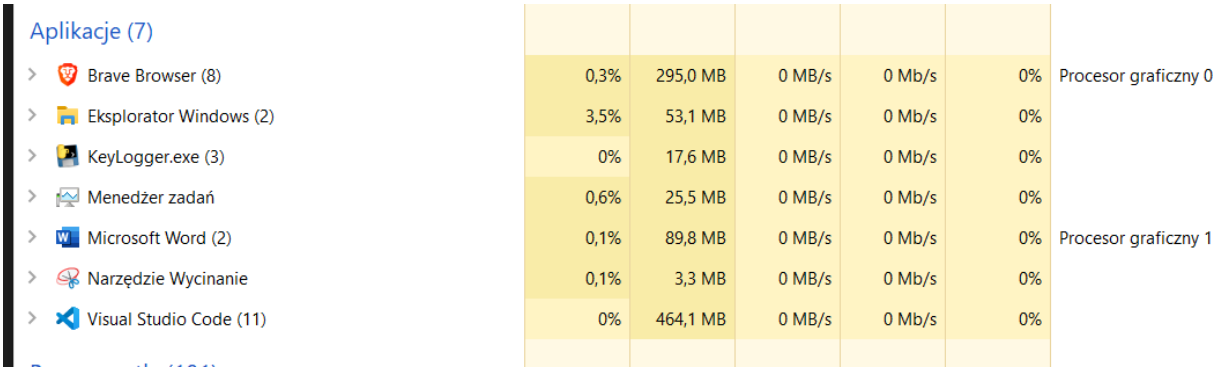

*Listing 1. Kod realizujący aplikację przechwytującą wpisywane klawisze.*

Przy pomocy biblioteki PyInstaller ze skryptu w języku Python został wygenerowany plik EXE. Następnie przy pomocy prostego skryptu w Powershellu skrypt jest uruchamiany w tle bez wiedzy użytkownika i będzie działać tak długo, dopóki proces nie zostanie zatrzymany.

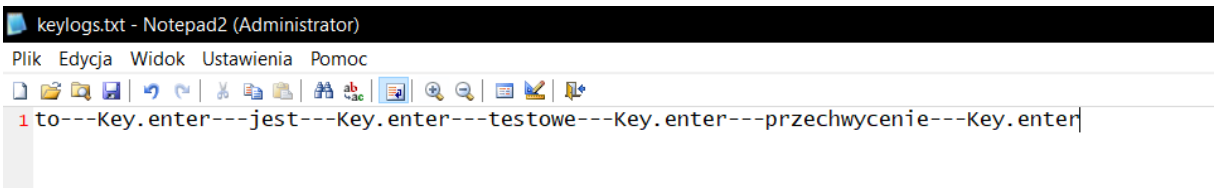



*Rys 3. Wygenerowany plik EXE oraz skrypt Powershell.*

Po uruchomieniu skryptu działa on w tle bez wiedzy użytkownika. Po uruchomieniu i przechwyceniu pierwszego wpisanego znaku tworzy on plik .txt, gdzie zapisywane są wszystkie przechwycone znaki.




*Rys 4. Keylogger działający w tle.*




*Rys 5. Przechwycone znaki zapisane w pliku keylogs.txt*

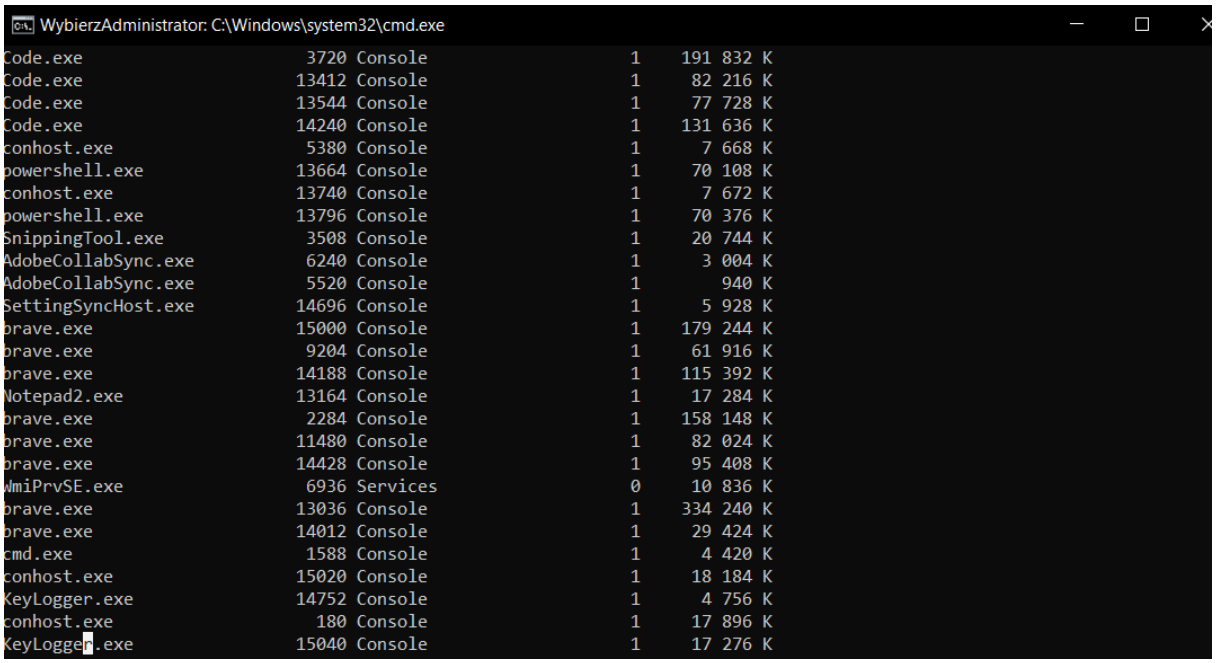
Po przeprowadzeniu ataku i przechwyceniu danych logowania osoba atakująca bez problemu zalogowała się na konto ofiary oraz zmieniła jej dane dostępowe do swojego konta, co w rezultacie dla ofiary oznacza całkowitą utratę konta bez możliwości jego odzyskania.

# *Metody prewencji przed atakiem typu KeyLogger*

Przejdźmy zatem do kluczowej kwestii, czyli jak sprawdzić, czy mam keyloggera? Szkodliwe oprogramowania mają jedną wadę – stały monitoring klawiatury wymaga działania w tle. Oznacza to, że na komputerze jest uruchomiony proces bądź usługa połączona z obcym adresem IP, która na bieżąco przesyła nasze dane z urządzenia. Do wyśledzenia keyloggera można zatem wykorzystać wiersz polecenia w systemie Windows. Stosowanie podstawowych środków bezpieczeństwa umożliwia wykrycie oprogramowań tego typu. Większość firm antywirusowych bowiem dodała najbardziej rozpowszechnione keyloggery do swoich baz. Oznacza to, że należy zainstalować program antywirusowy i regularnie aktualizować bazę zagrożeń. Porada być może brzmi banalnie, ale nadal wiele osób o tym zapomina. Na rynku dostępne są również narzędzia antyspyware specjalizujące się w wykrywaniu keyloggerów. Główny cel keyloggera to przechwycenie poufnych danych, dlatego należy dodatkowo wzmocnić ochronę poprzez wykorzystanie:

- dwuskładnikowego uwierzytelniania,
- jednorazowych haseł (do ich wygenerowania można użyć klucza USB lub specjalnego kalkulatora),
- wirtualnej klawiatury.

W przypadku tego projektu został napisany prosty skrypcik pokazujący usługi i procesy działające w tle z wykluczeniem procesów i usług systemowych. Pomaga to nam w lokalizacji danego zagrożenia i przerwania pracy programu przechwytującego nasze dane. Ponadto dobrą praktyką byłoby wprowadzenie tzw. haseł jednorazowych lub tokenów, dzięki czemu nawet w przypadku przechwycenia tych danych osoba atakująca nie mogłaby się nimi posłużyć na naszą niekorzyść.




*Rys 6. Lista procesów działających w tle.*

## *Wnioski i spostrzeżenia*

Projekt obejmował zarówno przygotowanie ataku typu Keylogger oraz przygotowanie się i obrona przed tego typu atakami. Według mnie o wiele prościej jest być po stronie atakującego, tym bardziej, że w tym przypadku wiemy kogo chcemy zaatakować i jakie dane zdobyć. Samo zaprogramowanie keyloggera nie jest zbyt trudne, o wiele cięższe jest odpowiednie przeprowadzenie ataku przy pomocy utworzonego narzędzia w taki sposób, aby użytkownik nie był świadomy utraty swoich poufnych danych. Stając po stronie ofiary trzeba zawsze mieć świadomość, że ktoś może nas podsłuchiwać w danym momencie, więc warto wszędzie rozszerzyć autoryzacje o weryfikację dwuetapową. Warto również zainstalować oprogramowanie antywirusowe i regularnie aktualizować bazy danych wirusów ale najważniejsza kwestia to być świadomym użytkownikiem i poruszać się po sieci z dużą ostrożnością.